

Vulnerability Management Policy

SIMULATED / FICTIONAL EVIDENCE — FOR EDUCATIONAL USE ONLY

Organization	CloudFlow Technologies (fictional SaaS vendor)
Product in scope	CloudFlow CRM
Classification	Confidential — Internal Use / Simulated Evidence
Approval status	Approved for simulation (not a live corporate record)
Document owner	Jordan Hale, Chief Information Security Officer
Document ID	POL-VM-005
Version	1.6
Effective date	10 February 2025
Last review date	15 January 2026

1. Scanning

Authenticated vulnerability scanning of production and staging is performed at least monthly. Unauthenticated external scanning is performed weekly. Software composition analysis runs on each build and weekly on default branches.

2. Remediation windows

- Critical: 7 days from confirmation.
- High: 30 days from confirmation.
- Medium: 90 days from confirmation.
- Low: best effort, not to exceed 180 days without exception.

Exceptions require CISO approval, a compensating control, and an expiry date not exceeding 90 days without re-approval. The 30-day High window applies to application and infrastructure findings, including internet-facing assets unless a shorter target is agreed with a customer in a security exhibit.

3. Penetration testing

An independent penetration test of the SaaS environment is performed at least annually. Findings are entered into the vulnerability register and follow the SLAs above unless the tester's severity mapping is adjusted by the CISO with written rationale.

4. Patching of cloud images

Base images are rebuilt at least monthly. Emergency patches follow the Critical SLA.